Activity 2 Secure Exchange Review and Improvement

Student: Laurence Matthew B Manuel **Section:** BSIT 3A **Project:** Project 29 Thesis Consultation Reminder System
Assessment: Week 14 Verification and Improvement Activity **Executed:** 8 November 2026 Asia/Manila

Scope and criteria

This review covers source revision `03d9ed3`, which preserves the controlled Week 14 working tree based on Week 13 tag `v1.0.0` at `707ef93`. The coordinator is authorized to create an envelope; only the assigned adviser may receive it. The review inspects source, protected configuration, HTTPS, tamper/replay behavior, secret exposure, recovery, and residual risk. The instructor retains assessment authority.

Acceptance required a trusted HTTPS connection, HTTP 200 for one valid receive, HTTP 409 for its replay, HTTP 422 for altered and invalid envelopes, HTTP 403 for an unauthorized receiver, no second receipt, no plaintext on failure, and no key/token/ciphertext in tracked evidence or security logs.

Inspection record

Review area	Method	Actual result
Source	Inspected routes, middleware, controller, `SecureExchange`, migration, tests, Flutter API and receiver states	Server creates and opens envelopes; key never enters Flutter. Role, recipient, assignment, expiry, tag and replay checks are explicit.
Configuration	Verified blank example values, ignored keyring/TLS paths, and `git check-ignore`	Live keyring and private TLS keys are ignored under `backend/storage/app/private`. Example configuration contains no secret.
Transport	Short-lived localhost CA and certificate, HTTPS gateway, TLS verification script	TLS 1.3 with `TLS_AES_256_GCM_SHA384`; localhost certificate valid through 15 November 2026; client without CA rejected with `unable to get local issuer certificate`.
Tamper and replay	PHPUnit plus live HTTPS script	Altered ciphertext returned 422; replay returned 409; one accepted receipt remained.
Invalid and unauthorized	Live HTTPS script and feature tests	Empty envelope returned 422; panel/other adviser returned 403; expired session and envelope tests returned 401/422.
Wrong or unavailable key	Configuration-controlled feature tests	Wrong key failed authentication; missing key returned generic 503; restored key recovered normal success.
Safe logging	Mocked logger assertion plus review of saved JSON/log fields	Events contain event, entity, actor, correlation and allowlisted reason/message ID; not key, token, ciphertext, plaintext agenda, or request body.
Secret scan	Ignore checks, tracked-source patterns, actual generated-key comparison	No generated key match in proposed tracked artifacts; protected files remain ignored.

Controlled failure and improvement

Prediction. A real Flutter login over the TLS gateway should complete its CORS preflight and then send credentials only over HTTPS. If the gateway removes preflight headers, the browser should block the request and the UI should show a safe network error rather than sending an insecure fallback.

Initial observation. The first live browser login displayed `Cannot reach the service. Check the API and try again.` The TLS gateway forwarded `Origin` but not `Access-Control-Request-Method` or `Access-Control-Request-Headers`, so Laravel could not return the full CORS permission response. No plaintext fallback or saved workflow mutation occurred.

Improvement. The gateway request-header allowlist was expanded to forward only the two CORS preflight headers in addition to the already approved headers. This preserves a small explicit boundary and does not forward cookies or arbitrary browser headers.

Rerun and regression. The corrected preflight returned HTTP 204 with origin `https://localhost:8444`, methods `GET, POST, PATCH, OPTIONS`, and the approved request headers. The browser then signed in over HTTPS, created an envelope, accepted it as the adviser, and rejected a repeat. Backend tests remained 21 passing with 199 assertions; Flutter analysis remained clean and 18 tests passed; the release web build succeeded.

Actual security results

Evidence ID	Scenario	Expected	Actual	Outcome
SEC-HTTP-01	Authenticated envelope accepted	200	200	Pass
SEC-HTTP-02	Replay rejected	409	409	Pass
SEC-HTTP-03	Altered ciphertext rejected	422	422	Pass
SEC-HTTP-04	Unauthorized role rejected	403	403	Pass
SEC-HTTP-05	Invalid envelope rejected	422	422	Pass
SEC-TLS-01	Controlled CA trusted	TLS success	TLS 1.3 success	Pass
SEC-TLS-02	Missing trust anchor	Certificate rejection	Rejected	Pass

One-page interpretation

Observed facts. The first browser attempt failed at the CORS boundary while keeping the API unreachable from the UI, which proved that the client did not silently downgrade. After the minimal gateway fix, the same path worked over HTTPS. Both live and isolated tests rejected altered, replayed, expired, invalid, unauthorized, wrong-key, missing-key, and invalid-certificate cases. The application retained correlation references and a unique acceptance receipt without logging protected material.

Reasoned conclusions. The controlled failure was a real integration weakness, not a cryptographic failure. It demonstrates why secure transport includes browser policy and gateway configuration as well as a certificate. The selected fix was narrower than forwarding every header and preserved the explicit trust boundary. Test-layer diversity matters: PHPUnit could prove time travel, database counts, wrong keys, and log contexts, while the live browser exposed the CORS defect that unit tests did not. The evidence supports a controlled prototype claim, not absolute security or production readiness.

Recommendations. Retain the allowlisted gateway, but replace the Python evidence gateway with a maintained reverse proxy before deployment. Add a manual screen-reader/Tab-order review, inactivity-based session expiry, automated previous-key removal, time-drift monitoring, and protected centralized audit storage. Remove the local CA from the user trust store after the review period if it is no longer needed.

Acknowledgment

The review uses Laravel, Flutter, PHP OpenSSL, Python cryptography and standard TLS libraries. AI assistance supported implementation review, evidence organization and report drafting. Exact institutional acknowledgment wording remains subject to instructor guidance.